

אפיון כניסה למערכת — Login ו-Authentication

ה-slice הראשון של אימות אמיתי: מסך כניסה עם Google ו-Microsoft, והחלפת הזהות המדומה. גרסה 1.2 · יולי 2026. משלים את אפיון פאנל הניהול (§8) ואת מסמך מסכי פאנל הלקוח.

1. מטרה והקשר

כיום הזהות מדומה: השרת מזהה משתמש קבוע דרך middleware שנבנה מראש להחלפה. מסמך זה מגדיר את ההחלפה — כניסה אמיתית, ניהול sessions, וחיבור לטבלת org_users הקיימת — בלי לשנות אף מסך קיים: כל ההרשאות (תפקידים, הרשאות דאטה, audit) כבר עובדות מול הזהות, ורק מקור הזהות מתחלף.

החלטת MVP (עדכון: לקוחות הניסוי הם לקוחות אמיתיים עם דאטה אמיתי): שלוש דרכי כניסה, כולן ללא סיסמה — (1) אימייל + קוד אימות חד-פעמי שנשלח למייל — שיטת הברירה-מחדל, עובדת לכל משתמש מוזמן בלי תלות בספק; (2) Continue with Google; (3) Continue with Microsoft. אין סיסמאות בכלל: אין מה לאחסן, אין reset flow, אין דליפות. כל שלוש הדרכים מובילות לאותו חשבון לפי אימייל מאומת.

2. מסך הכניסה

2.1 מבנה

- עמוד מלא, ממורכז, מינימלי: לוגו SEMA, שורת headline אחת ("היעץ העסקי של הארגון שלך"), שדה אימייל + כפתור "המשך", מפריד "או", שני כפתורי SSO, וקישור "נתקלת בבעיה?" שפותח mailto לאדמין הארגון.
- שלב קוד האימות (אחרי הזנת אימייל מוזמן): "שלחנו קוד בן 6 ספרות ל-name@x.com" — שדה קוד עם autofocus ו-autocomplete=one-time-code, כפתור "שלח שוב" (נעול 60 שניות עם ספירה), קישור "החלף אימייל". הקוד תקף 10 דקות, שימוש חד-פעמי, עד 5 ניסיונות.
- כפתורי SSO לפי הנחיות המותג של הספקים: "Continue with Google" ו-"Continue with Microsoft" — אייקון רשמי, טקסט מלא, גודל זהה, ללא כפתור "ראשי" ביניהם.
- אם הארגון העלה לוגו (הגדרות ארגון) והגישה היא דרך קישור הזמנה — הלוגו של הארגון מוצג מעל הכפתורים ("מצטרף/ת ל-E-Commerce").
- שפת המסך: לפי שפת הדפדפן בכניסה ראשונה (עוד אין ארגון ידוע); אחרי זיהוי — שפת הארגון. RTL מלא בעברית.
- מצב טעינה: הכפתור שנלחץ נכנס למצב spinner והשני מושבת; חזרה מ-redirect מציגה מסך ביניים "מתחברים..." — לעולם לא מסך לבן.

2.2 מצבי שגיאה (כולם במסך, לא ב-alert)

- אימייל לא מוזמן: "החשבון name@x.com אינו מוזמן ל-SEMA. פנה לאדמין הארגון שלך." — בלי לרמוז אם הארגון קיים (מניעת enumeration).
- משתמש מושעה: "החשבון שלך הושעה. פנה לאדמין הארגון."
- הזמנה שפגה: "קישור ההזמנה פג. בקש מהאדמין לשלוח מחדש." (האדמין רואה Resend במסך המשתמשים).
- ביטול בצד הספק / שגיאת רשת: הודעה כללית + כפתור נסה שוב. כל שגיאה נשארת במסך הכניסה — אין דף שגיאה נפרד.

3. זרימת האימות

3.1 אימייל + קוד חד-פעמי (שיטת ברירת המחדל)

- הזנת אימייל ← אם הוא מוזמן, נוצר קוד 6 ספרות אקראי (CSPRNG); בשרת נשמר רק hash שלו (כמו סיסמה) עם תפוגת 10 דקות. אימייל לא מוזמן מקבל את אותו מסך "שלחנו קוד" בדיוק — בלי לשלוח כלום — כדי למנוע enumeration.
- אימות הקוד: עד 5 ניסיונות, שימוש חד-פעמי, קוד חדש מבטל את קודמו. "שלח שוב" — cooldown של 60 שניות; מגבלת קצב לפי אימייל ולפי IP (למשל 5 קודים לשעה).
- שליחת האימייל: דרך SMTP המוגדר ב-env (ספק לבחירתה של בעלת המערכת). תבנית מייל דו-לשונית מינימלית: הקוד, תוקף, "לא ביקשת? התעלם". במצב פיתוח (SEMA_AUTH_MODE=mock) הקוד נכתב ללוג השרת במקום להישלח.

3.2 SSO — פרוטוקול

- Microsoft Entra ID (Google (OAuth 2.0 / OpenID OIDC Authorization Code + PKCE מול שני הספקים: (v2.0 endpoint, כולל חשבונות עבודה ואישיים). state ו-nonce חתומים בכל בקשה.
- צד שרת בלבד: ה-frontend מפנה ל-`auth/{provider}/start/`; ה-callback נקלט בשרת, שמאמת את ה-token מול הספק ומנפיק session. אף token של ספק לא מגיע לדפדפן ולא נשמר — נשלף רק אימייל מאומת, שם ותמונה.
- רק אימייל מאומת (`email_verified`) מתקבל; אימייל לא מאומת נדחה עם הודעת השגיאה הכללית.

3.3 התאמת זהות (invite-only)

- אין הרשמה חופשית: האימייל מהספק חייב להתאים לשורת `org_users` קיימת (`active` או `invited`). ההתאמה לפי אימייל בלבד, `case-insensitive`.
- כניסה ראשונה של מוזמן: `status` הופך `active, joined_at` נקבע, שם ותמונה נמשכים מהספק (ניתנים לעדכון עתידי בהגדרות אישיות). נרשם `audit: user.joined`.
- אותו משתמש יכול להיכנס פעם עם Google ופעם עם Microsoft — אם האימייל זהה, זה אותו חשבון. אין קשירה לספק ספציפי.
- MVP: אימייל שייך לארגון אחד (מגבלה קיימת של `org_users`). ריבוי ארגונים לאותו אימייל + מסך בחירת ארגון — V2.

3.4 Sessions

- Session צד-שרת: טבלת `sessions(id, user_id, created_at, last_seen_at, expires_at, user_agent)`. בדפדפן — `cookie` אחד: `httpOnly, Secure, SameSite=Lax`.
- תוקף: 14 יום עם הארכה בשימוש (`sliding`); אי-פעילות מעל 14 יום — כניסה מחדש. Logout מוחק את ה-session בשרת.
- משתמש שהוסר/הושעה באמצע session: ה-middleware בודק סטטוס בכל בקשה — ניתוק מיידי עם הודעה במסך הכניסה (סוגר את מצב הקצה מאפיון 8§).
- כניסה, יציאה וכישלון כניסה (אימייל לא מוזמן) נרשמים ב-audit בקטגוריית "גישה" — כולל `provider`. כישלונות מוגבלים בקצב (`rate limit`) לפי IP.

4. אינטגרציה עם הקיים

- ה-middleware הקיים (`get current user`) מקבל מימוש חדש מבוסס session במקום הזהות הקבועה — כל שאר הקוד (`require_client_admin, data scopes, audit actor`) נשאר ללא שינוי. דגל `SEMA_AUTH_MODE=mock|real` מאפשר להריץ פיתוח וטסטים במצב הישן.
- קישור הזמנה (מהמסך Users): מוביל למסך הכניסה עם הקשר ההזמנה (לוגו הארגון, "מצטרף/ת ל..."). ההזמנה נצרכת רק אחרי אימות מוצלח של אותו אימייל.
- כפתור Logout נוסף ל-workspace switcher בתחתית הסיידבר (שם המשתמש + תפקיד כבר מוצגים היום).
- Redirect אחרי כניסה: אם המשתמש הגיע מקישור עמוק (שיחה, פאנל ניהול) — חוזרים אליו; אחרת למסך הבית.

5. אבטחה — דרישות רוחב

- Secrets של הספקים (`client_id/secret`) ב-env בלבד, לעולם לא בקוד או בלוג. Callback URLs נעולים ל-allowlist.
- הגנת CSRF (על ה-state callback) ועל כל ה-SameSite API + בדיקת Origin על mutations.
- אין enumeration: אותה הודעת שגיאה לאימייל לא קיים ולארגון לא קיים; זמני תגובה אחידים.
- 2FA לאדמינים, ניהול sessions פעילים ("התנתק מכל המכשירים"), ו-SAML ארגוני V2 (מתועדים באפיון הראשי 5.3, §7§).

6. היקף MVP מול V2, ושלביות המימוש

- MVP: מסך כניסה + אימייל עם קוד אימות + Google + Microsoft, invite-only, sessions עם ניתוק מיידי, audit גישה, logout, דגל mock לפיתוח. V2: ריבוי ארגונים, 2FA לאדמינים, ניהול מכשירים, SAML/SCIM, remember-device.

6.1 שלביות מימוש (החלטה — יולי 2026)

- שלב 0 — עמוד הלוגין בלבד (מבוצע כעת): כל ה-UI וכל מצבי המסך, frontend בלבד עם תגובות מדומות, כפתורי SSO במצב "בקרו". האפליקציה נשארת נגישה עם הזהות המדומה; העמוד קיים לצורך אישור עיצובי והדגמה — מוכן להתחבר ל-backend בלי שינוי עיצוב.
- שלבים A+B — האימות האמיתי (קוד במייל + sessions, ואז SSO): חסומים עד קיום hosting אמיתי עם HTTPS. הנימוק: secure cookies ו-OAuth callbacks אינם ניתנים לבדיקה אמينة מול localhost — מימוש לפני שיש דומיין וסביבה יפיק ביטחון כוזב.
- אבן דרך מקדימה נדרשת (מחוץ למסמך זה): החלטת hosting — סביבה, דומיין, HTTPS, ניהול secrets. עם סגירתה, שלב A משוחרר והוא חוסם ההשקה ללקוח הניסוי הראשון.